Financiera PARA EL Bienestar

POLÍTICA DE DESARROLLO DE SOFTWARE

ENERO 2025

TCM-GSIC-POL-007-25

Descripción:

El presente documento contiene los lineamientos aplicables para el desarrollo de Software realizado por Financiera para el Bienestar (antes Telecomunicaciones de México), procurando que el tratamiento de la información conserve la confidencialidad, integridad y disponibilidad.

CONTROL DOCUMENTAL

Información del documento

Nombre del documento	Política de desarrollo de software
ID o Nomenclatura	**TCM-GSIC-POL-007-24**
Servicio o Nombre del Proyecto	Sistema de Gestión de Seguridad de la Información (SGSI)
Vigencia o Periodicidad	Anual
Anexos (cuando apliquen)	N/A
Observaciones	Sin Observaciones

Control de versiones

Autor	Versión	Fecha de versión	Modificaciones
Subdirección de Tecnologías de la Información y Comunicaciones	3.1	Enero 2025	• Por modificación en el estatuto orgánico institucional se actualizan los nombres de áreas y nombres de titulares. • Actualización de la política. • Inserción de nuevos requerimientos

Elaborado por:	Revisado por:	Aprobado por:
Ing. Fatima Saudysareth Ibarra Soberanes		
Con cargo a la Gerencia de Seguridad de la Información y Comunicaciones		
	Mtro. Gustavo Jiménez Pérez	**Act. Juan Herrada Velázquez**
C. Laura Yuliana López Chacón	Gerente de Seguridad en Informática y Comunicaciones	Subdirector de Tecnologías de la Información y Comunicaciones
Comisionada a la Gerencia de seguridad en informática y Comunicaciones		

Fecha de elaboración o revisión	Vigencia	Clasificación
enero 2025	Anual	Confidencial

2. GLOSARIO DE TÉRMINOS, SIGLAS Y ACRÓNIMOS

A continuación, se muestra el glosario de términos, siglas y acrónimos que pueden ser encontrados a lo largo del presente documento.

Términos / Siglas / Acrónimos	Significado
Ambiente de desarrollo	Área de trabajo que proporciona condiciones suficientes al programador para realizar la generación y pruebas de código antes de pasar al ambiente de preproducción.
Ambiente de preproducción	Área de trabajo que proporciona condiciones suficientes al programador para probar y ajustar la funcionalidad de los módulos antes de implementarlos en el ambiente de producción.
Amenaza	Posible acto o circunstancia interna o externa que puede explotar, de manera intencional o circunstancial, la debilidad presente en un activo de información. Una amenaza puede tener diferente nivel de riesgo de acuerdo con los escenarios en los que se presente.
Arquitectura tecnológica	Estructura de hardware, software y redes de telecomunicación requerida para dar soporte a la implementación de los aplicativos de cómputo, soluciones tecnológicas o servicios de TIC en FINABIEN.
Autenticación	Procedimiento informático que permite identificar de manera individual e inequívoca los atributos de un usuario, con la finalidad de que éste pueda acceder a un aplicativo de cómputo o a un servicio electrónico.
Base de datos	Conjunto de datos pertenecientes a un mismo contexto y almacenados sistemáticamente para su posterior uso.
Código fuente	Conjunto de líneas de texto escritas en algún lenguaje de programación que contiene las instrucciones dadas a la computadora para realizar la funcionalidad deseada de un programa.
Criptografía Cifrado	Son técnicas las cuales vuelven incomprensible el mensaje y a una clave que permite, justamente, comprenderlo al usuario que tiene permiso la lectura.
Entorno de pruebas	Es un entorno de pruebas o cerrado que aísla los cambios en el código, fruto de la experimentación.
Estándar	Conjunto de especificaciones técnicas u otros criterios precisos para ser usados consistentemente como reglas, guías, o definiciones de características para asegurar la interoperabilidad o compatibilidad de los productos, procesos y servicios.
Evaluación de riesgos	Evaluación de las amenazas y vulnerabilidades relativas a la información y a las instalaciones de procesamiento de esta, la probabilidad de que ocurran y su potencial impacto en la operación del Instituto.
Fases de desarrollo	Cada una de las etapas que componen el proceso de desarrollo de un sistema informático, definidas como: Levantamiento de requerimiento, desarrollo, pruebas y liberación en producción.
FINABIEN	Financiera para el Bienestar, antes Telecomunicaciones de México.
GCCEI	Gerencia de Centros de Cómputo y Equipamiento Informático.
GDSA	Gerencia de Desarrollo de Sistemas Administrativos.
GDSI	Gerencia de Desarrollo de Sistemas Informáticos.
GSIC	Gerencia de Seguridad en Informática y Comunicaciones.
ISO/IEC 27001:2013	Estándar para la seguridad de la información.
Mantenimiento del sistema	Obtención de una nueva versión del sistema informático, necesaria para eliminar errores detectados o incorporar mejoras en el diseño o en la obtención de resultados.
OIC	Órgano Interno de Control
Plataforma de desarrollo	Entorno de software común en el cual se desenvuelve la actividad de desarrollo de sistemas informáticos.
Proyecto informático de desarrollo de sistemas	Conjunto de acciones que implican la aplicación de recursos para la automatización de procesos, o parte de ellos, mediante la creación de un sistema informático o la modificación de uno existente.

1. CONTENIDO

CONTROL DOCUMENTAL 2
1. CONTENIDO 4
2. GLOSARIO DE TERMINOS, SIGLAS Y ACKONIMOS 5
3. LENGUALE INCLUYENTE Y NO DISCRIMINATORIO 7
4. INTRODUCCION 7
4.1 Objetivo 7
4.2 Alcance 8
5. ROLES Y RESPONSABILIDADES 8
6. LINEAMIENTOS 8
6.1 Lineamientos generales 8
6.2 Dè la segrepación de los ambientes 11
6.5 Dei código fuente de las aplicaciones 12
6.4 De la séguridad en los sistemas 13
7. DETALLE DE NORMALIZACION 13
8. REFERENCIAS 14
9. FIRMAS DE APROBACION 14

Av: de las Tólecomunicaciones *SIN* Col, Loyes de Reforma, Alcaldia lelapalapa, C.P. 09130, Ciudad de México.
Tes. (35) 30 09 11 00. www.finat@inusob.ml

Responsable de desarrollo de sistemas de información:	Servidor público que representará, dirigirá y coordinará al área que desarrolla el proyecto informático durante todas sus fases.
Repositorio	Es un sitio centralizado donde se almacena, organiza, mantiene y difunde información digital, habitualmente bases de datos o archivos informáticos.
Rollback	Es una operación que devuelve a un sistema o base de datos, a algún estado previo funcional o en estado nominal.
Sistema informático	Conjunto de componentes físicos (hardware), lógicos (software) y humanos que se organizan para realizar una tarea o un proceso específico.
Software	Conjunto general de programas que conforman el equipamiento o soporte lógicos de una computadora digital.
SGSI	Sistema de Gestión de Seguridad de la Información.
STIC	Subdirección de Tecnologías de la Información y Comunicaciones.
Vulnerabilidad	Cualquier debilidad que puede ser utilizada/explotarse para causar pérdida o daño al sistema.

3. LENGUAJE INCLUYENTE Y NO DISCRIMINATORIO

El lenguaje empleado en la **Política de Desarrollo de Software** no busca generar ninguna distinción, ni marca diferencias entre hombres y mujeres, por lo que las referencias o alusiones en la redacción hechas hacia un género representa a ambos sexos.

4. INTRODUCCIÓN

Es fundamental que los sistemas de información cumplan con lineamientos básicos de seguridad para garantizar la confidencialidad, integridad y disponibilidad de la información. Además, deben apegarse al Acuerdo TIC, publicado en el DOF el 6 de septiembre de 2021, que establece políticas para el uso de tecnologías de información, gobierno digital y seguridad en la Administración Pública Federal.

Asimismo, es indispensable aplicar mejores prácticas en el desarrollo seguro de software, ya sea interno o externo, con el objetivo de reducir vulnerabilidades y garantizar la seguridad y operación de los sistemas.

4.1 Objetivo

Definir los lineamientos necesarios para garantizar la confidencialidad, integridad y disponibilidad de la información involucrada en los desarrollos de software, abarcando su generación, almacenamiento, procesamiento, transmisión y eliminación. Además, establecer un marco tecnológico de referencia que oriente el desarrollo y la documentación de sistemas seguros, en cumplimiento con los estándares técnicos aplicables, para Financiera para el Bienestar (FINABIEN), anteriormente Telecomunicaciones de México.

4.2 Alcance

Los lineamientos establecidos en la presente política deberán ser aplicados en todos los desarrollos de sistemas nuevos o ya existentes en FINABIEN, donde se involucre información en cualquier etapa de su ciclo de vida, aplican tanto para desarrollo interno como para externo. Lo anterior basado en la metodología de la GDSI y GDSA.

5. ROLES Y RESPONSABILIDADES

DIRECCIÓN DE ADMINISTRACIÓN (DA)

- Aprobar esta política
- Proveer los recursos, activos y herramientas tecnológicas necesarias de forma física y lógica a los usuarios finales para la prestación de los servicios, en caso de aplicar.
- Comunicar, difundir y concientizar al interior de FINABIEN la importancia de mantener los criterios de esta política en pro de adoptar una cultura respecto a la seguridad de la información.

SUBDIRECCIÓN DE TECNOLOGÍAS DE LA INFORMACIÓN Y COMUNICACIONES.

- La GSIC, es responsable de la creación de esta política, de revisarla y actualizarla al menos una vez al año, en apoyo con los titulares de la GDSI y GDSA.
- El titular de la STIC, en conjunto con el titular de la GDSI y la GDSA; aprobaran la presente política y apoyaran a la GSIC para el cumplimiento de la misma.
- La STIC deberá comunicar a los involucrados en FINABIEN (Personal interno, externo, servicio social), la importancia de mantener los criterios de esta Política y dar a conocer que de lo contrario el personal que lo incumpla, deberá ser sancionado según los lineamientos que determine el OIC.
- La GSIC establecerá los lineamientos de seguridad de la información, para que las áreas de desarrollo GDSI y GDSA implementen los mecanismos descritos en esta política para garantizar la seguridad en los sistemas o aplicaciones desarrolladas para el uso de FINABIEN.
- La GDSI y la GDSA, así como todas aquellas áreas que desarrollen software en FINABIEN son responsables de que todos los aplicativos de cómputo desarrollados o financiados por FINABIEN se encuentren registrados en el inventario de bienes y servicios de TIC.
- La GSIC es responsable del resguardo del código fuente, a través del repositorio destinado para ello, asegurando que este se encuentre siempre actualizado y disponible.
- La GDSI y la GDSA, así como todas aquellas áreas que desarrollen software en FINABIEN, son responsables de efectuar pruebas unitarias y de integración previas a la liberación en producción.
- La GSIC, es responsable de realizar las pruebas de código estático y dinámico a los sistemas y aplicaciones desarrollados en FINABIEN.

6. LINEAMIENTOS

6.1 Lineamientos generales

- Las direcciones que conforman FINABIEN deberán coordinar, dirigir y supervisar en cada una de sus áreas el cumplimiento de los lineamientos establecidos en la presente política.

- Los desarrolladores de aplicaciones deberán salvaguardar la confidencialidad de la información, a través de la firma de una carta de confidencialidad y un acuerdo de no divulgación (NDA), por sus siglas en inglés mediante el formato F-GSIC-07 carta de confidencialidad. Dicho formato deberá ser entregado a la GSIC.

- Los derechos de autor de todos los sistemas implementados y desarrollados por el personal de FINABIEN durante sus periodos activos en la institución, son propiedad de Financiera para el Bienestar mismos que deberán ser registrados ante el Instituto Nacional del Derecho de Autor.

- FINABIEN preferentemente deberá implementar y desarrollar aplicativos basados en software libre.

- Para el caso de los desarrollos externos además de sujetarse a la normatividad de adquisiciones vigente, el costo que se genere para la contratación lo asumirá el área solicitante.

- Las direcciones de área que conforman FINABIEN deberán solicitar el desarrollo de sistemas y aplicaciones, ya sean Sustantivos, Administrativos, o aplicaciones web, y para soluciones tecnológicas a sus actividades, solicitarlo por escrito y de manera formal a la STIC, sustentando el requerimiento nuevas soluciones tecnológicas y servicios de TIC´S.

- El análisis y viabilidad del desarrollo deberá ser evaluado por la Dirección General indicando a la STIC la priorización de los desarrollos.

- Las condiciones de operación de cada uno de los ambientes serán determinadas por la GDSI y GDSA en conjunto con la GCCEI de acuerdo con los recursos informáticos con los que cuente y el análisis de requerimientos que se identifique entre dicha gerencia y el requirente.

- Como unidad central coordinadora de la actividad informática de FINABIEN, la STIC con apoyo de las áreas de infraestructura y de desarrollo, serán las responsables a nivel institucional de definir la ubicación de los recursos informáticos necesarios para llevar a cabo los proyectos de desarrollo que sean requeridos en FINABIEN.

- Las disposiciones de las Políticas serán de observancia general y obligatoria para la STIC, así como la GDSI y GDSA, con los respectivos apoyos de la GCCEI y la GSIC.

- Todas aquellas áreas que desarrollen aplicativos en FINABIEN conforme a la metodología que se tenga establecida deberán de generar la documentación del soporte documental del desarrollo del sistema informático, en cuyo caso no cuenten con una metodología, la documentación enunciativa más no limitativa deberá contener al menos lo siguiente:
    - Plan de trabajo alto nivel.
    - Acta de proyecto que contenga:
        - Requerimientos del área usuaria.
        - Definición de entregables.
        - En caso de que aplique, minuta de reuniones.
        - Aceptación del alcance por parte del área usuaria.

- Diseño y la arquitectura del software.
- Pruebas unitarias e integrales con sus resultados.
- Transferencia de conocimiento.
  - Guía técnica del uso del aplicativo.
  - Memoria técnica.
- Acta de entrega.
  - Aceptación del proyecto por parte del área usuaria.

- La documentación inherente a las implementaciones y desarrollos en FINABIEN:
  - Deberá salvaguardarse en un repositorio a cargo de la STIC el cual deberá ser respaldado cada mes.
  - Los archivos respaldados deberán ser identificados adecuadamente:
    - Identificando el archivo con año, mes y día, seguido del nombre del aplicativo que hace referencia, terminando con el tipo de información que contiene (diagrama, código, requisitos, etc.).
  - El responsable del repositorio documental será asignado por la STIC, mediante un oficio donde se le notifique las actividades a desempeñar, así como la periodicidad de estas.
  - Las áreas que desarrollen software deberán asignar a un enlace él cual enviará al responsable del repositorio documental la actualización de documentación cada que se efectúa un cambio de versión como se indica en los lineamentos generales.
  - El responsable del repositorio documental deberá contar con un inventario de aplicativos y documentación de los desarrollos para su control con apoyo del responsable del repositorio de código fuente.
- Todos los sistemas informáticos deberán contar con el modelo de base de datos y con las descripciones de las estructuras de datos utilizadas (diccionario de datos).
- Todas las bases de datos relacionales deben pasar mínimo por la segunda forma normal del proceso de normalización.
- Todo proyecto de desarrollo se considera como proyecto informático y como tal está sujeto a las reglas descritas en la presente política.
- Las áreas que desarrollen software en la institución se encargarán de mantener actualizados los registros con la información correspondiente al proyecto de desarrollo. En el repositorio de código fuente.
- El área usuaria deberá de solicitar el mantenimiento del aplicativo al área que desarrollo dicho aplicativo; siempre y cuando se identifiqué y justifiqué la necesidad de ajustar o cambiar el sistema para mejorar el desempeño y cobertura de este.

- Las gerencias de desarrollo deberán proponer soluciones de mejora ante los aplicativos elaborados.

- Cualquier sistema informático deberá ser desarrollado atendiendo a los estándares para el desarrollo de sistemas, arquitecturas, políticas de seguridad (que sean establecidas por la GSIC) y otros instrumentos normativos que al respecto emita la UTIC, u aquellos que estén vigentes en FINABIEN.

- Como parte de los requerimientos iniciales de los proyectos de desarrollo informáticos, se deberán establecer criterios para asegurar la disponibilidad, confidencialidad e integridad de la información que se esté manejando.

- Se deberá vigilar que el desarrollo de software se apegue a estándares de desarrollo seguro conforme a las revisiones internas efectuadas por la GSIC.

- La GSIC deberá realizar por lo menos una vez al año, análisis de código estático y dinámico a todos los sistemas de información.

- Los procesos de autenticación en el desarrollo de nuevas soluciones tecnológicas y/o servicios de TIC, deberán establecer perfiles y/o roles con los privilegios mínimos necesarios que restrinjan el acceso a las funcionalidades, datos, objetos y sistemas de información que requieran para realizar sus tareas.

6.2 De la segregación de los ambientes

- Se deberá contar con segregación de ambientes, para todos los sistemas que así lo requieran. Los ambientes mínimos con los que se deberá contar son:
    - Desarrollo.
    - Pruebas.
    - Producción.

- Para el caso de las actualizaciones, o nuevas versiones deberán:
    - Ser generadas en ambiente de desarrollo/prueba.
    - Probadas en el ambiente de prueba (lo más apegado a un ambiente de producción) para la validación de los componentes del sistema informático, previo a su liberación a producción.
    - La prueba deberá realizarse por lo menos 24 hrs., previas a la liberación en producción.
    - No se liberarán aplicativos los viernes y lunes, lo anterior con la finalidad de garantizar la disponibilidad del soporte técnico de los desarrolladores de los sistemas informáticos. Tampoco se podrá los lunes por el alto volumen transaccional. A menos que se trate de un caso de emergencia o excepción, el cual deberá justificarse.

- No se podrán hacer cambios en ambientes de producción sin pasar por el proceso de control de cambios.

- Para la implementación de los sistemas y/o actualizaciones en producción, se deberá generar un plan de retorno (Rollback), en caso de que se presente alguna falla.

- En ninguna circunstancia se deberá utilizar información productiva de aplicaciones con información confidencial y reservada, para realizar pruebas en ambientes de desarrollo. Toda verificación de desarrollo de sistemas informáticos deberá realizarse en un ambiente de prueba.

6.3 Del código fuente de las aplicaciones

- Todo el código fuente deberá ser resguardado en un repositorio, mismo que deberá estar siempre actualizado y disponible a cargo de la GSIC, en el cual únicamente tendrán acceso el personal de desarrollo (desarrolladores y responsables de las áreas de desarrollo) con identificación de perfiles, así como el personal encargado del control de cambios en ambiente productivo.

- El responsable del repositorio de código fuente deberá de efectuar una recertificación de cuentas cada 3 meses, solicitándoles vía correo electrónico a las áreas de desarrollo el listado del personal que deberá tener acceso al repositorio.

- El responsable del repositorio de código fuente deberá desactivar los accesos al personal de desarrollo, tras validar inactividad en las sesiones dentro del repositorio cada 3 meses exceptuando a los responsables de las áreas de desarrollo.

- El repositorio que almacena los códigos fuente deberá ser independiente del repositorio que almacena la documentación de los desarrollos.

- Las liberaciones en ambiente productivo, solo se realizarán por el personal que la GSIC designe si se cuenta con la última versión del código fuente en el repositorio.

- El responsable del repositorio del código fuente deberá validar que los desarrolladores suban las últimas versiones del código fuente al repositorio compilando el código resguardado.

- La GSIC deberá tener el control de la administración del versionamiento del aplicativo informático en producción.

- La GCCEI realizará a la STIC el respaldo del repositorio asignado para el almacenamiento del código fuente.

- El encargado del repositorio de código fuente deberá validar que los respaldos generados por parte de la GCCEI que se conserven al menos tres ciclos (diario, semanal, mensual, entre otros.), conforme defina el responsable de la información.

6.4 De la seguridad en los sistemas

- Las aplicaciones que operen sobre datos críticos, sensibles o confidenciales; deberán garantizar que el procesamiento y transferencia de la información se realice a través de mecanismos que garanticen su confidencialidad, integridad y disponibilidad considerando al menos los elementos de seguridad siguientes:

    - Las comunicaciones de las aplicaciones deben viajar en canales cifrados (HTTPS, SFTP, SSH, por poner algunos ejemplos).
    - Los desarrollos deberán apegarse a buenas prácticas, considerando las versiones actualizadas de las aplicaciones de soporte.
    - Utilizar certificados de confianza propios de FINABIEN o emitidos por una autoridad certificadora.
    - Delimitar el cierre de sesión por inactividad.

  Los usuarios deberán utilizar contraseñas seguras para el acceso a los recursos informáticos conforme a la Política de Control de Acceso Lógico.

7. DETALLE DE NORMALIZACIÓN

Con base en las mejores prácticas, la identificación de los puntos mencionados en este documento se tomó como referencia los siguientes lineamientos:

- Acuerdo TIC 2021
- Norma **ISO 33000 Calidad de procesos de desarrollo software**
- Norma **ISO 9001 Software para la mejora de calidad en software**
- Norma **ISO/IEC ISO 27001:2022**

8. FIRMAS DE APROBACIÓN

Con fundamento en el artículo 15, fracción XXXII del Estatuto Orgánico de Financiera para el Bienestar correspondiente al Titular de la Dirección Ejecutiva de Administración:

> ***XXXII.*** *Dirigir el cumplimiento de la normatividad en materia de TIC del Organismo, para regular su operación, continuidad y seguridad;*

Así como a la función 27, asignada a la Dirección de Administración en el Manual de Organización Institucional de Telecomunicaciones de México, que señala:

> *27. Definir las políticas y procedimientos en materia de desarrollo de sistemas y de seguridad lógica de los sistemas informáticos y de telecomunicaciones privadas del Organismo.*

La presente política se acredita por:

MTRO. JULIAN DOMINGUEZ LÓPEZ PORTILLO
DIRECTOR DE ADMINISTRACIÓN
En ejercicio de las funciones de la Dirección Ejecutiva de Administración; De conformidad con lo previsto en el Artículo CUARTO TRANSITORIO, Fracción I del Estatuto Orgánico de Financiera para el Bienestar (DOF:17/04/2024).

ACT. JUAN HERRADA VELAZQUEZ SUBDIRECTOR DE TECNOLOGÍAS DE LA INFORMACIÓN Y COMUNICACIONES	**MTRO. GUSTAVO JIMÉNEZ PÉREZ** GERENTE DE SEGURIDAD EN INFORMÁTICA Y COMUNICACIONES
T.S.U. OCTAVIO SANTIAGO ARELLANO GERENTE DE DESARROLLO DE SISTEMAS INFORMÁTICOS	**MTRO. GILBERTO ZENDEJAS RODRIGUEZ** GERENTE DE CENTROS DE CÓMPUTO Y EQUIPAMIENTO INFORMÁTICO

Fecha de elaboración o revisión	Vigencia	Clasificación
enero 2025	Anual	Confidencial

MTRO. OCTAVIO EMMANUEL TORRES MÁRQUEZ GERENTE DE LA RED TELEGRÁFICA INTEGRADA	**NÉSTOR ILICH GALAVIZ JORDÁN** GERENTE DE MONITOREO DE APLICACIONES INFORMÁTICAS